

Déploiement d'une architecture Zero Trust pour la sécurisation d'un réseau universitaire

« Ne jamais faire confiance, toujours vérifier »

Sokhna Maimouna Cisse

Mouhamed El Bachir Thiam

L2 SRTA

Chef de projet : **Pr Ibrahima Ngom**

Encadrant : **Marc Momar Tall**

Plan de la présentation

1

**Concepts de
cybersécurité
et modèle Zero Trust**

2

**Étude des solutions
Ubiquiti et Fortinet**

3

**Conception de
l'architecture
sécurisée**

4

**Déploiement et
configuration**

5

**Tests d'intrusion et
analyse des résultats**

Conclusion générale, perspectives et recommandations

Contexte et problématique

Les universités : des cibles privilégiées

Données sensibles, populations hétérogènes (étudiants, enseignants, personnel, IoT), réseau ouvert par nature.

Les limites de la sécurité périmétrique

La confiance implicite à l'intérieur du réseau ne résout plus des menaces internes toujours plus sophistiquées.

Menaces Spécifiques

- DOS/DDOS
- Brute Force
- Mouvement lateral
- ARP Spoofing
- Exploitation IOT

Question de recherche : comment sécuriser un réseau universitaire où des centaines d'utilisateurs se connectent chaque jour sans faire confiance à personne par défaut ?

Sécurité périmétrique vs Zero Trust

Principe de base	Confiance implicite intérieure	Aucune confiance par défaut
Périmètre	Défini (intérieur / extérieur)	Inexistant
Contrôle d'accès	Basé sur la position réseau	Basé sur l'identité / contexte
Segmentation	Faible	Stricte (micro-segmentation)
Surveillance	Périmétrique	Continue et globale

Le modèle Zero Trust

Never trust, always verify. Formalisé par John Kindervag (Forrester, 2010), adopté par le NIST (SP 800-207, 2020) : aucun utilisateur, équipement ou flux n'est considéré fiable par défaut.

1

Vérification systématique

Chaque accès est authentifié et autorisé

2

Moindre privilège

Accès strictement limité au besoin du rôle

3

Micro-segmentation

Le réseau est divisé en zones isolées

4

Surveillance continue

Trafic et comportements monitorés en permanence

5

Authentification renforcée

MFA sur les accès sensibles

MFA identifié comme axe d'amélioration prioritaire — non déployé dans la maquette (périmètre du projet)

Solutions technologiques retenues

FortiGate

Pare-feu de nouvelle génération (NGFW)

- DPI + IPS/IDS via FortiGuard
- Contrôle applicatif & filtrage web
- VPN SSL / IPSec
- Support natif VLAN 802.1Q
- NAT & serveur DHCP par interface

Ubiquiti UniFi

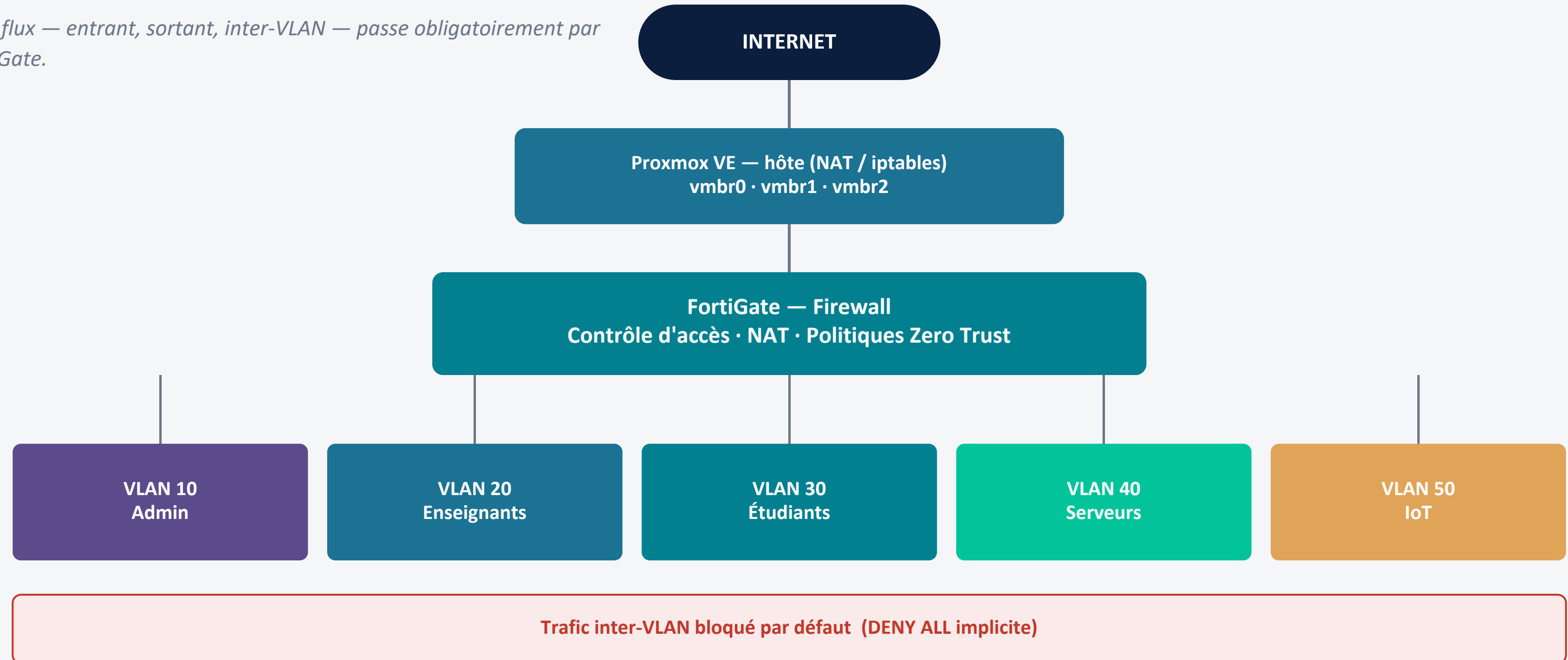
Couche d'accès réseau

- Switches en mode trunk / access
- Points d'accès WiFi 6 (SSID ↔ VLAN)
- Contrôleur de gestion centralisée
- Coût compétitif, forte évolutivité
- Simulé par les bridges Proxmox

Retenus face à OPNsense et Sophos XG pour leur richesse fonctionnelle et leur intégration VLAN native.

Architecture réseau globale

Tout flux — entrant, sortant, inter-VLAN — passe obligatoirement par FortiGate.



Infrastructure de virtualisation — Proxmox VE

3 bridges réseau

0

vmbr0 WAN — accès Internet
192.168.1.204/24

1

vmbr1 LAN interne — trunk VLAN 802.1Q
manuel

2

vmbr2 Lien Proxmox ↔ FortiGate
10.0.0.1/30

7 machines virtuelles déployées

FortiGate	FortiOS 7.x	WAN/LAN
VM-Admin	Debian 13	VLAN 10
VM-Enseignant	Debian 13	VLAN 20
VM-Étudiant	Debian 13	VLAN 30
VM-Serveur	Debian 13	VLAN 40
VM-IoT	Debian 13	VLAN 50
Kali-Attaquant	Kali 2026.1	VLAN 30

Politiques Zero Trust : refus par défaut

9 politiques configurées sur FortiGate — tout trafic non couvert tombe sous la règle implicite *implicit deny*. Accès Internet (HTTP/HTTPS/DNS/PING) autorisé pour tous via NAT.

Matrice de communication inter-VLAN — seuls 3 flux explicitement autorisés vers le VLAN Serveurs

Destination →		Admin	Enseig.	Étud.	Serveurs	IoT
Source ↓	Admin	—	DENY	DENY	ACCEPT	DENY
	Enseig.	DENY	—	DENY	ACCEPT	DENY
	Étud.	DENY	DENY	—	ACCEPT	DENY
	Serveurs	DENY	DENY	DENY	—	DENY
	IoT	DENY	DENY	DENY	DENY	—

Méthodologie des tests d'intrusion

Attaquant : **Kali Linux 2026.1 (192.168.30.50)** — positionné dans le **VLAN 30 Étudiants**

Scénario : poste étudiant compromis — menace interne, la plus représentative en environnement universitaire.

1

Scan de vulnérabilités

```
nmap -sV / --script vuln
```

2

Force brute SSH

```
Hydra + rockyou.txt
```

3

Scan agressif + IPS

```
nmap -sS -A -T4
```

4

Déni de service

```
hping3 - flood SYN
```

5

ARP Spoofing

```
arp spoof / dsniff
```

Bilan global des tests d'intrusion

Scan de vulnérabilités

Aucune vulnérabilité critique détectée

Élevé

Isolation inter-VLAN

Aucun hôte détecté hors VLAN 30

Élevé

Force brute SSH

Bloqué par FortiGate (inter-VLAN)

Élevé

Scan agressif / IPS

Détecté — pic CPU à 99 %

Bon

Attaque DoS (SYN flood)

98 279 paquets envoyés, 0 reçus

Élevé

ARP Spoofing

Vulnérabilité détectée — DAI absent

Moyen

Vulnérabilité résiduelle : ARP Spoofing

Empoisonnement du cache ARP

arpspoof fait croire à VM-Étudiant que l'adresse MAC de Kali correspond à celle de FortiGate (192.168.30.1).

Résultat de l'attaque

Perte totale de connectivité de la victime (100 % packet loss vers sa passerelle) — test mené sans relais IP actif.

Cause racine

Absence de Dynamic ARP Inspection (DAI) dans la configuration FortiGate actuelle.

Portée de la vulnérabilité

- ✓ Limitée au VLAN 30 (intra-segment)
- ✓ N'affecte pas les autres VLANs
- ✗ La micro-segmentation inter-VLAN reste intacte

Recommandation : activer le Dynamic ARP Inspection (DAI) sur FortiGate / commutateurs d'accès.

Objectifs atteints

- ✓ Conception d'une architecture segmentée en 5 VLANs
- ✓ Déploiement effectif d'un pare-feu Zero Trust (FortiGate)
- ✓ Isolation quasi complète entre populations universitaires
- ✓ Accès Internet contrôlé pour l'ensemble des utilisateurs
- ✓ Validation par 5 tests d'intrusion réalistes
- ✓ Vulnérabilités résiduelles identifiées et documentées

Conformité NIST SP 800-207

- ✓ Politiques d'accès dynamiques
- ✓ Micro-segmentation réseau
- ✓ Refus par défaut / moindre privilège
- ... Authentification renforcée (MFA)
- ... Vérification continue de posture
- ... Collecte centralisée des événements

Architecture partiellement conforme — la segmentation réseau est solide, l'axe identité/appareil reste à construire.

Perspectives d'amélioration

Court terme

- Activer le Dynamic ARP Inspection (DAI)
- Activer les signatures IPS FortiGuard
- Durcir les accès résiduels

Moyen terme

- Authentification multifacteur (MFA)
- SIEM et supervision centralisée
- NAC + WiFi Ubiquiti segmenté

Long terme

- Certification ISO 27001
- Zero Trust pour les accès distants
- Gestion unifiée des identités (IAM)

Merci pour votre attention

Questions ?

Sokhna Maimouna Cisse
Mouhamed El Bachir Thiam
L2 SRТА — UCAD